

SENIOR ENGINEERING AUDIT

EscaLeads

Visual Architecture & Audit

A graphical end-to-end walkthrough of the production codebase —
tech stack, database, APIs, request flows, security, and SEO.

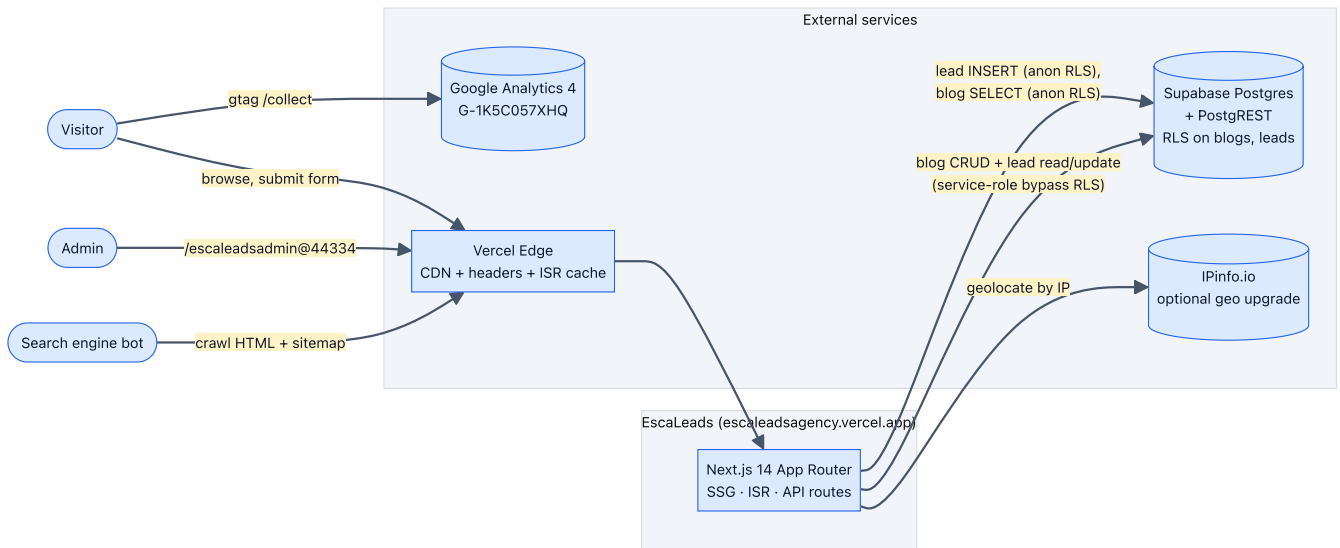
Next.js 14 · React 18 · Supabase · Vercel
Repository: [ali-rafey/My-A](#)

Table of contents

1. System context (who talks to what)
2. Tech stack — layered view
3. Repository layout
4. Routing map (every URL)
5. Database — ER + RLS
6. API surface
7. Request flows (sequence diagrams)
8. Authentication & security (layered defense)
9. Data fetching strategies
10. Sanitization pipeline
11. Styling architecture
12. Build & deploy pipeline
13. SEO audit findings

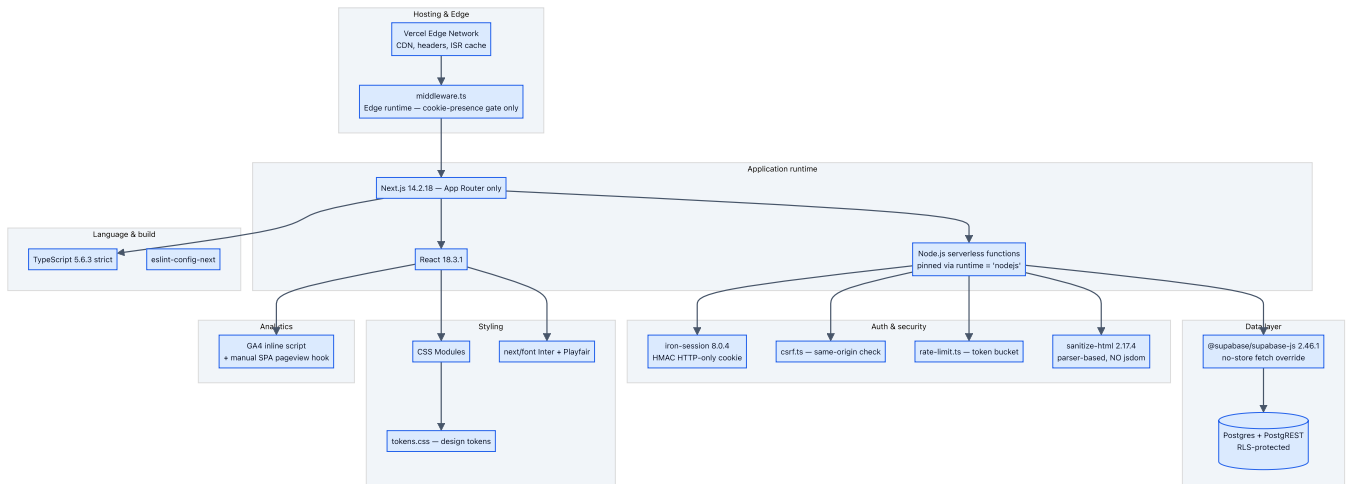
1. System context

The actors, the application, and every external system it touches. The site lives at `escaleadsagency.vercel.app` and is a public marketing site plus a hidden admin portal.



2. Tech stack

Pinned versions and intentional choices, from runtime to language. No Tailwind, no styled-components, no Edge runtime for data routes.



3. Repository layout

Annotated tree showing where every concern lives.

```
.
├── app/                                Next.js App Router
│   ├── layout.tsx                     root shell, GA4, JSON-LD
│   ├── page.tsx                      homepage (6 sections, revalidate 3600)
│   ├── sitemap.ts / robots.ts        auto-generated
│   ├── services|how-it-works|our-work|contact/page.tsx
│   ├── blogs/
│   │   ├── layout.tsx                {children} + {modal} slots
│   │   ├── page.tsx                  /blogs listing (ISR 60s)
│   │   ├── BlogModalDialog.tsx       client overlay
│   │   ├── [slug]/page.tsx           SEO page (SSG + ISR, nodejs)
│   │   └── @modal/(.)[slug]/page.tsx intercepting modal
│   ├── api/
│   │   ├── leads/route.ts             POST public
│   │   └── admin/
│   │       ├── login | logout
│   │       ├── blogs/route.ts         GET, POST (withAdminGuard)
│   │       ├── blogs/[id]/route.ts    GET, PUT, DELETE
│   │       ├── leads/route.ts         GET
│   │       ├── leads/[id]/route.ts    PATCH, DELETE
│   │       ├── leads/export/route.ts  CSV
│   │       └── diagnostics/route.ts   self-test
│   └── escalateadmin@44334/          hidden admin
│       ├── layout.tsx                async – checks session, mounts AdminSidebar
│       ├── page.tsx                  Login OR Dashboard
│       ├── AdminSidebar.tsx          persistent left nav
│       ├── LoginForm.tsx
│       ├── admin.module.css           admin-LOCAL palette
│       ├── blogs/ · new/ · [id]/edit/ · BlogEditor.tsx
│       ├── leads/ · LeadRow.tsx · ExportButton.tsx
│       └── diagnostics/ · DiagnosticsRunner.tsx
├── components/
│   ├── navbar/Navbar.tsx
│   └── analytics/GoogleAnalytics.tsx
├── sections/                          homepage section components
│   ├── home/ · services/ · how-it-works/
│   ├── blogs-preview/ (async, reads Supabase)
│   └── our-work/ · contact/ (client form)
├── lib/
│   ├── supabase/ – server.ts, types.ts
│   ├── auth/ – session.ts, cookie.ts
│   ├── security/csrf.ts
│   ├── content/static.ts, blogs.ts
│   ├── admin-handler.ts               withAdminGuard
│   ├── client-info.ts                 IP + geo
│   ├── rate-limit.ts
│   ├── sanitize.ts                    regex-only, NO DOMPurify
│   └── sanitize-html.ts                parser-based allow-list
```

```
| |— text-to-html.ts          plain text → safe HTML
| |— format.ts
|— styles/                  FROZEN design tokens
| |— reset.css · tokens.css · global.css
|— middleware.ts           FROZEN – admin gate (Edge-safe)
|— next.config.mjs         FROZEN – CSP, HSTS, images
|— supabase/schema.sql     schema + RLS source of truth
|— .env.local.example
```


5. Database — ER + RLS

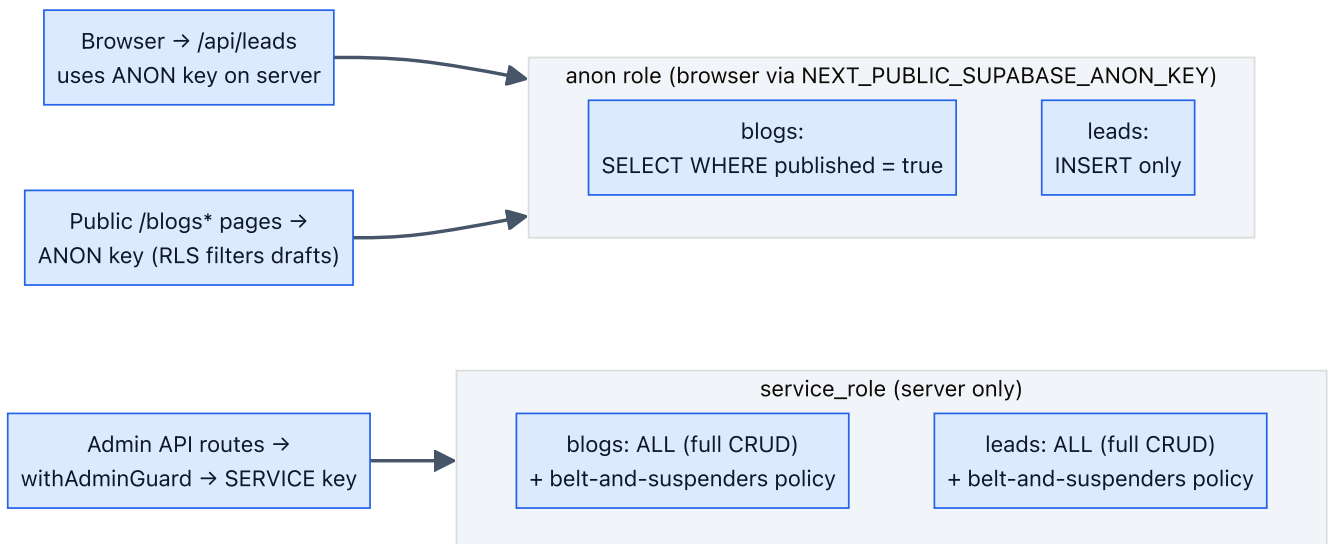
Two tables in the `public` schema. RLS is enabled on both; service-role bypasses; anon is tightly scoped.

Entity-relationship diagram

blogs			
uuid	id	PK	
text	title		
text	slug	UK	
text	content		sanitized HTML
text	cover_image		nullable
text	meta_description		nullable
text_array	tags		
boolean	published		
timestampz	created_at		
timestampz	updated_at		

leads			
uuid	id	PK	
text	name		
text	email		
text	phone		nullable
text	message		
boolean	read		
timestampz	created_at		
text	ip_address		server-only
text	country		
text	region		
text	city		

RLS policies per role



Belt-and-suspenders: the schema declares `alter table ... no force row level security` AND explicit "Service role full access" policies. Dual safeguard against a dashboard "Force RLS" toggle silently zero-ing out admin UPDATE/DELETE.

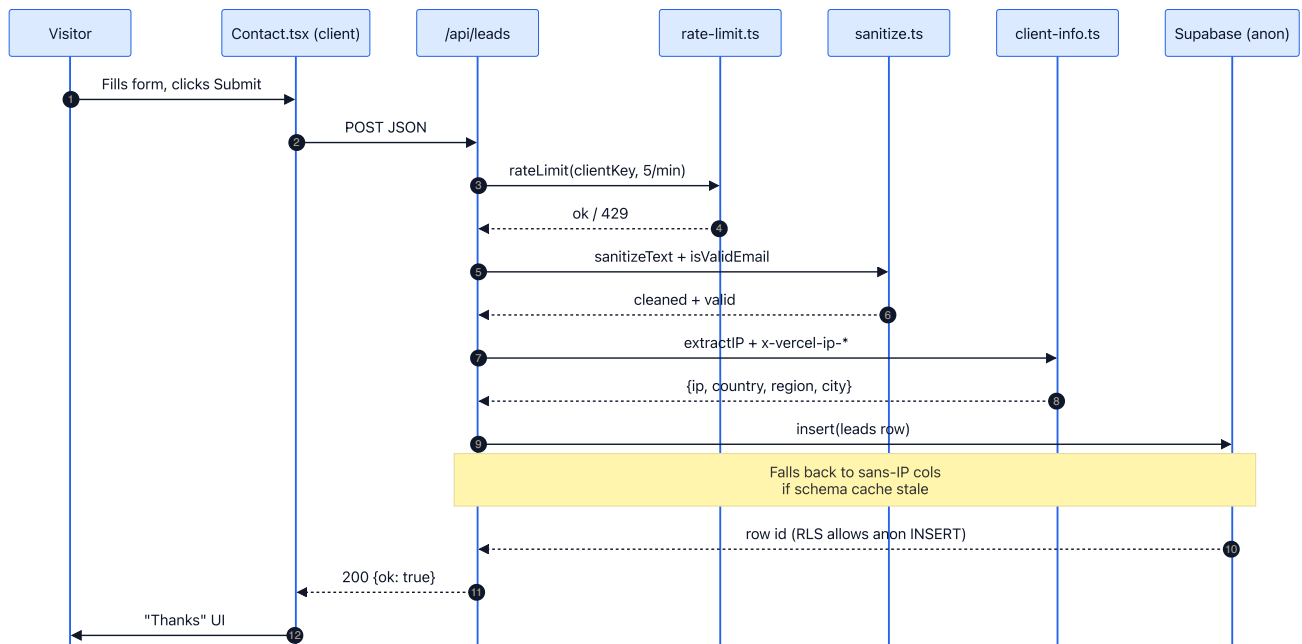
6. API surface

Every admin route is wrapped in `withAdminGuard(handler, opts?)` from `lib/admin-handler.ts` — single boundary for CSRF, rate limit, session check, and JSON error response.

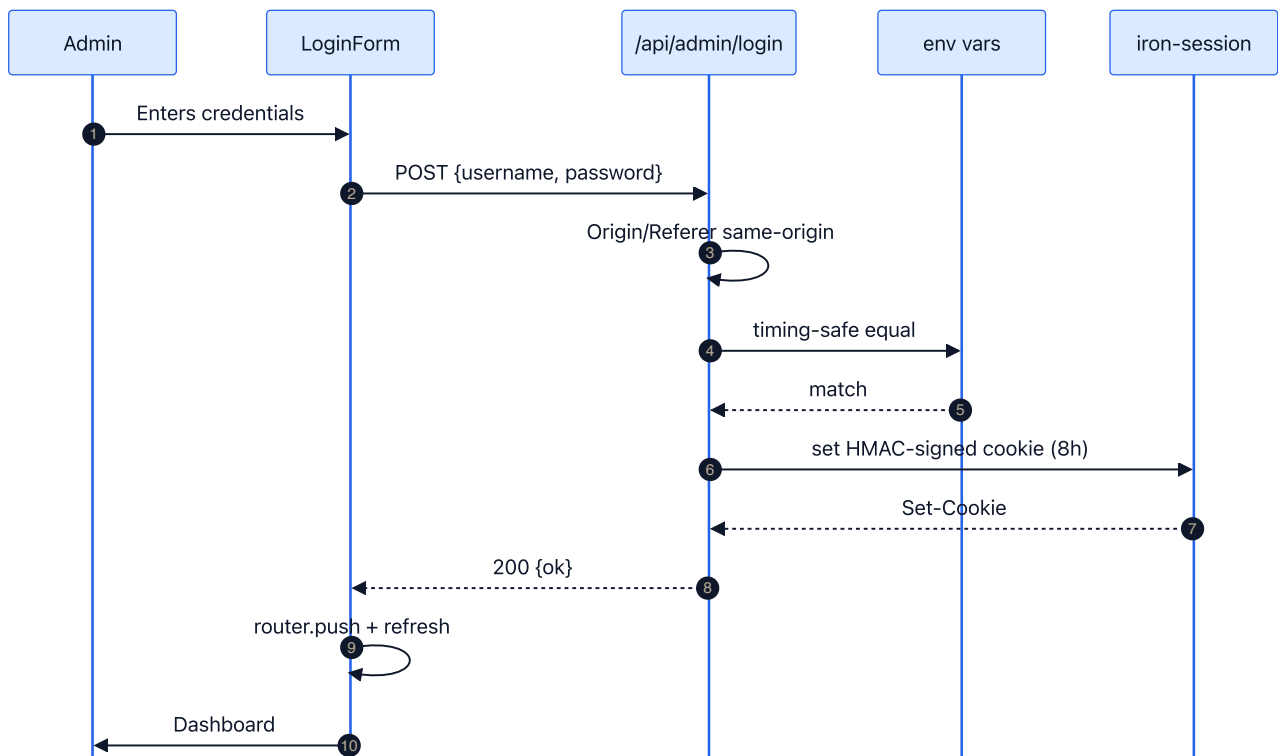
METHOD	PATH	AUTH	PURPOSE	RESPONSE
POST	/api/leads	public + rate-limit	Contact form submission	200 {ok, id} · 400 · 429
POST	/api/admin/login	public	Username/password sign-in	200 (sets cookie) · 401
POST	/api/admin/logout	session	Destroys cookie	200
GET	/api/admin/blogs	session	List all blogs incl. drafts	200 {blogs[]}
POST	/api/admin/blogs	session + CSRF + rate	Create blog	201 {blog} · 409 dup slug
GET	/api/admin/blogs/[id]	session	Get single blog	200 {blog} · 404
PUT	/api/admin/blogs/[id]	session + CSRF + rate	Update + revalidate	200 {blog} · 404
DELETE	/api/admin/blogs/[id]	session + CSRF + rate	Delete + revalidate	200 {ok} · 404
GET	/api/admin/leads	session	List leads	200 {leads[]}
PATCH	/api/admin/leads/[id]	session + CSRF + rate	Toggle read	200 {lead}
DELETE	/api/admin/leads/[id]	session + CSRF + rate	Delete lead	200
GET	/api/admin/leads/export	session	CSV download	200 text/csv
GET	/api/admin/diagnostics	session	Self-test env + RLS + CRUD	200 {checks[]}

7. Request flows

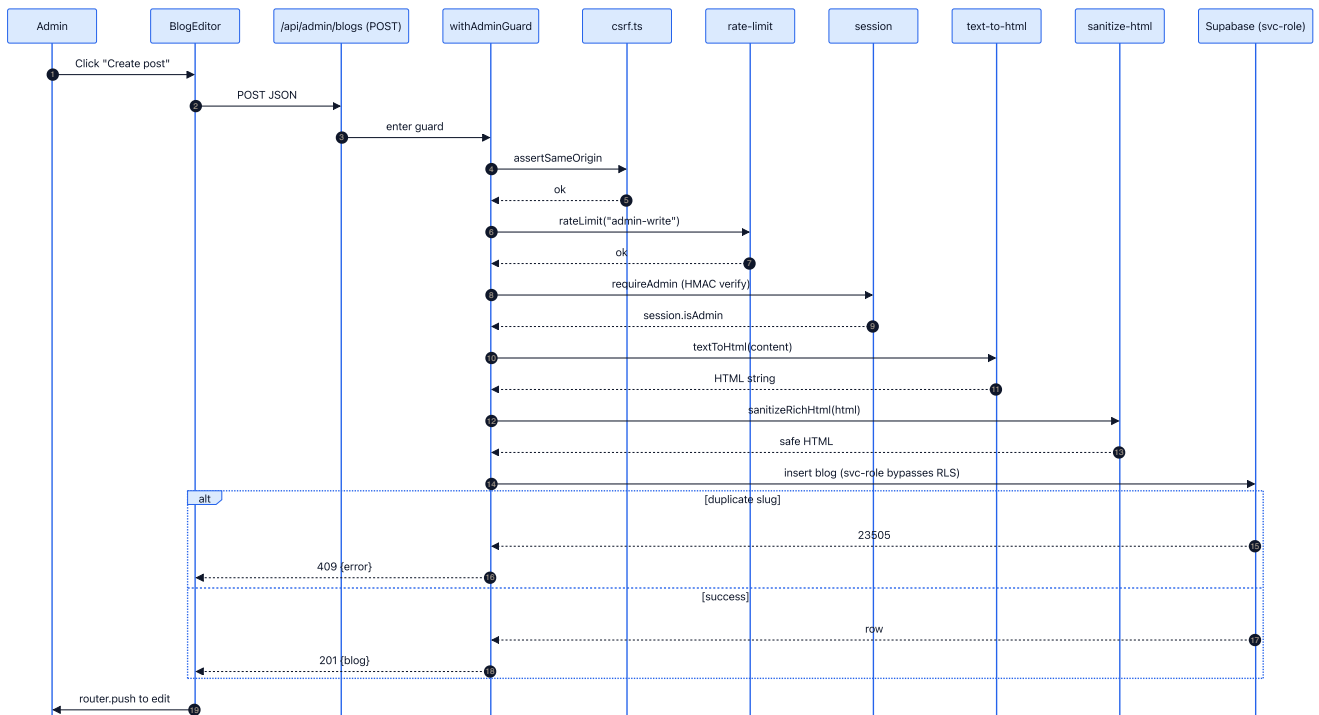
7.1 Visitor submits the contact form



7.2 Admin login



7.3 Admin creates a blog post



7.4 Visitor opens blog from listing (modal flow)



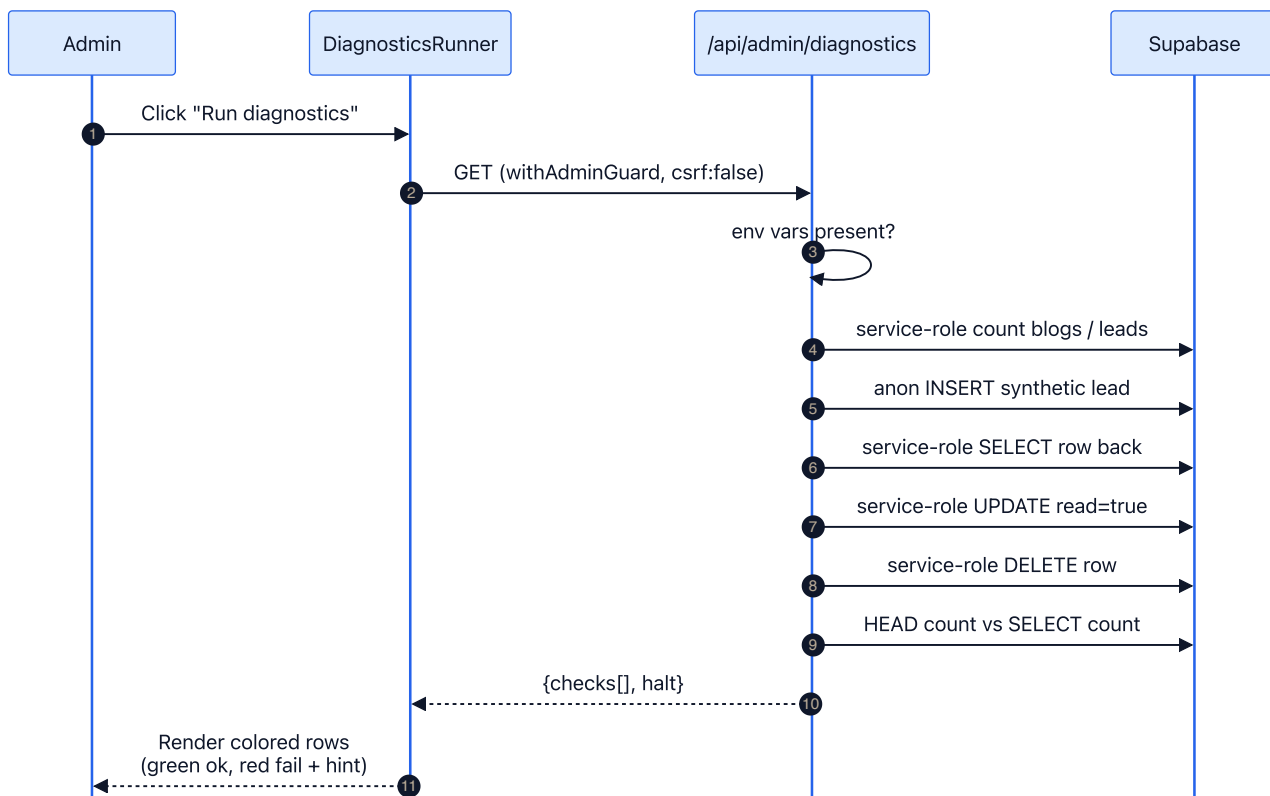
Syntax error in text
mermaid version 10.9.1

7.5 Visitor opens blog directly (SEO path)



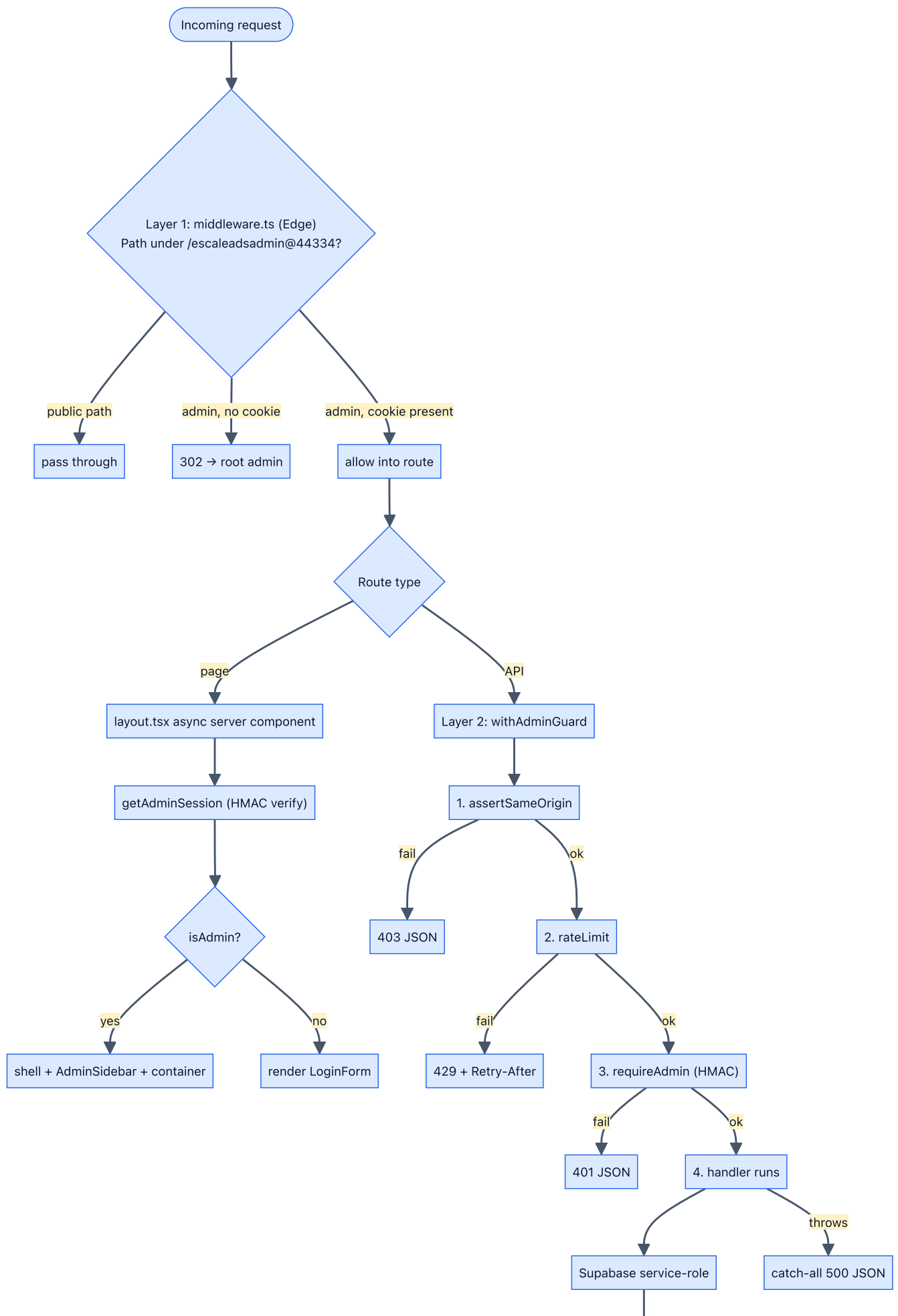
Syntax error in text
mermaid version 10.9.1

7.6 Diagnostics self-test



8. Authentication & security

Defense in depth, four layers. Each layer is a single source of truth — they don't duplicate logic.



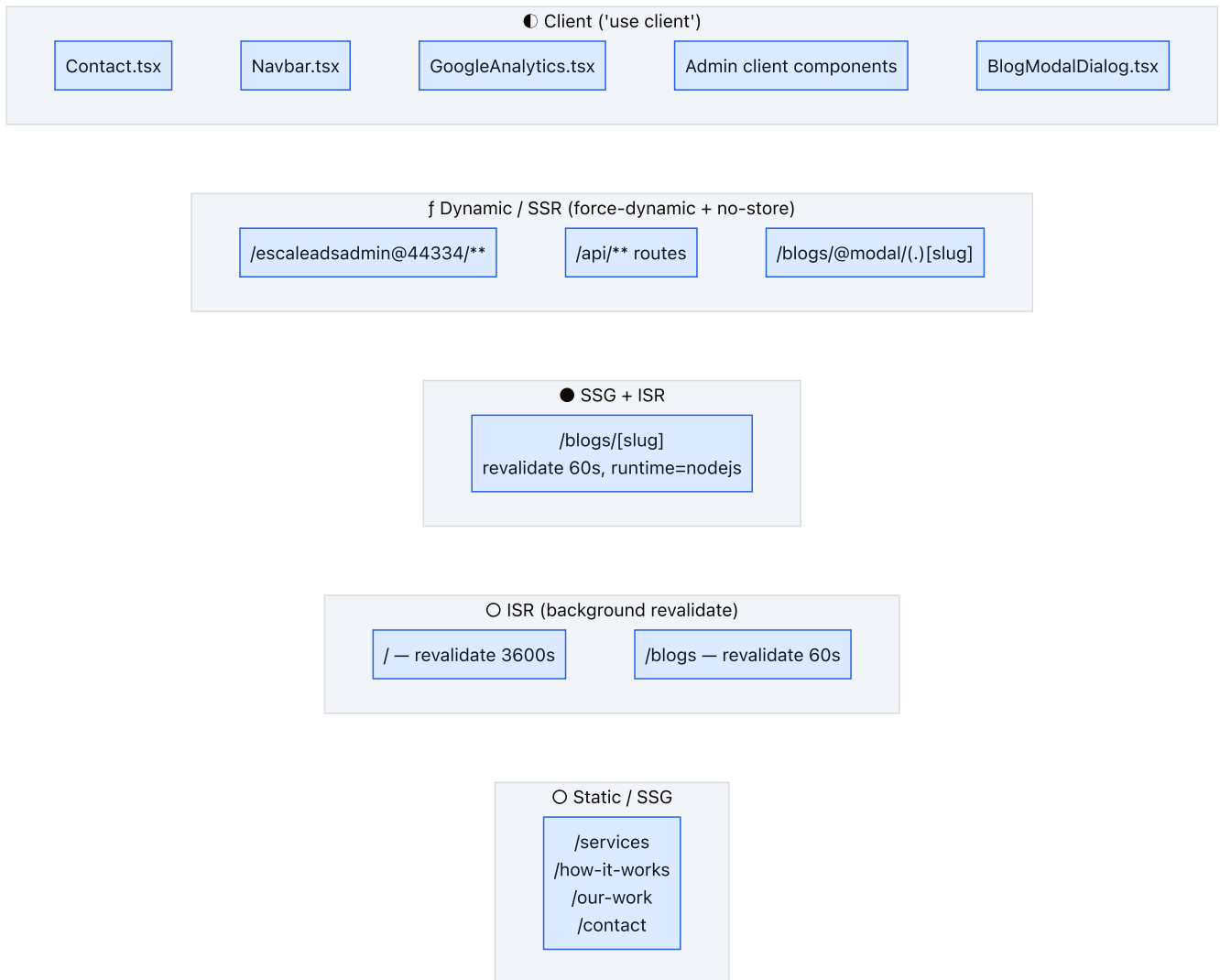


Layer 4: RLS
(anon scoped to published=true
+ INSERT-only leads;
service-role bypasses + explicit policies)

Why middleware doesn't validate the cookie: middleware runs in Edge runtime which can't import `iron-session` (pulls Node `crypto`). The cookie's HMAC is verified inside Node-runtime route handlers via `getAdminSession()` . Forging a cookie name passes the middleware; forging a valid HMAC is what's actually hard.

9. Data fetching strategies

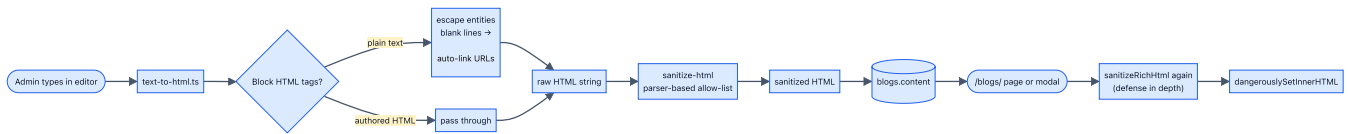
Which strategy serves which route, and why.



Cache-busting rationale: server-side Supabase clients pass a custom `global.fetch` that always sets `cache: 'no-store'`. Admin pages additionally export `dynamic = 'force-dynamic'`. Both are required — neither alone defeats every layer of Next.js caching.

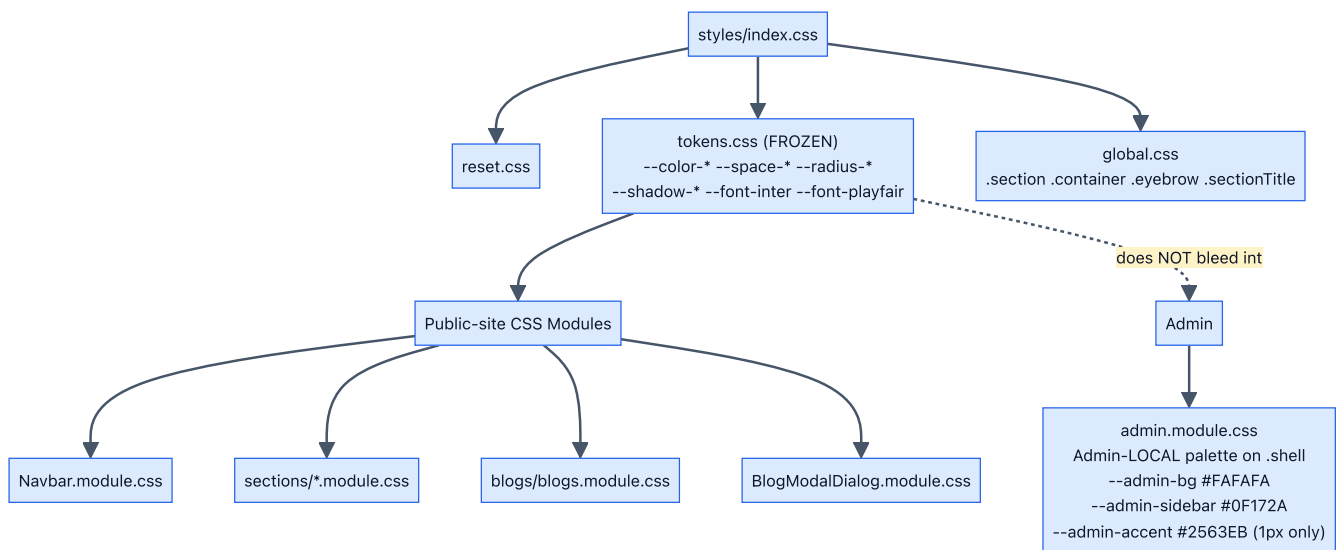
10. Sanitization pipeline

Two-pass sanitation on write, second-pass defense on read. No jsdom anywhere (the previous DOMPurify chain crashed on Vercel cold-starts).



Why `sanitize.ts` and `sanitize-html.ts` are separate: hot routes like `/api/leads` and `/api/admin/login` need only cheap regex stripping — pulling the parser into their bundle would inflate every cold-start.

11. Styling architecture





Syntax error in text

mermaid version 10.9.1

13. SEO audit findings

Findings from the live deploy. Severity by how much it blocks Google indexing.

● Critical — blocks SEO indexing

1. `NEXT_PUBLIC_SITE_URL` unset on Vercel — every URL falls back to `http://localhost:3000` . Affects canonical, sitemap, robots.txt host, OG `og:url` , JSON-LD URLs.

Fix: Set in Vercel project env vars:

`NEXT_PUBLIC_SITE_URL=https://escaleadsagency.vercel.app` and redeploy.

2. `/favicon.ico` returns **404**. No tab icon, no Google snippet icon.

Fix: Place `favicon.ico` in `public/` or point metadata `icons.icon` to `/logo-icon.png` .

3. `/og-image.png` returns **404**. Social shares (LinkedIn, Slack, FB, Twitter) have no preview image.

Fix: Add a 1200×630 branded image at `public/og-image.png` , or use existing `/logo-icon.png` as fallback.

4. `/apple-touch-icon.png` returns **404**. iOS home-screen icon missing.

Fix: Add a 180×180 PNG, or set `icons.apple` to `/logo-icon.png` .

● High — incomplete SEO

#	ISSUE	FIX
5	Sitemap missing <code>/services</code> , <code>/how-it-works</code> , <code>/our-work</code> , <code>/contact</code>	Add to <code>app/sitemap.ts</code>
6	No <code>og:image</code> in <code><head></code> anywhere	Add <code>openGraph.images</code> to root metadata
7	Sub-pages don't override Twitter card — every page tweets the homepage title	Add per-page <code>twitter</code> metadata
8	WebSite JSON-LD <code>searchAction</code> points to <code>/blogs?q=</code> which isn't implemented	Remove (or implement search)
9	<code>sameAs: []</code> empty in Organization JSON-LD	Remove or populate with real social URLs
10	<code>/services</code> , <code>/how-it-works</code> , <code>/our-work</code> , <code>/contact</code> have NO <code><h1></code> — section components use <code><h2></code> because the homepage hero owns the page h1	Add page-level <code><h1></code> wrapper to each route, or add <code>as</code> prop to sections

● Already good

• Article + BreadcrumbList JSON-LD on `/blogs/[slug]`

- Organization + WebSite JSON-LD globally
- Per-page `title` + `description` + `canonical` (correct, just localhost-poisoned)
- Security headers (CSP, HSTS, X-Frame-Options, Referrer-Policy, Permissions-Policy)
- `robots.txt` disallows `admin` + `/api`
- All rendered `<Image>` components have `alt` text
- Mobile viewport, theme color, format-detection meta
- GA4 with manual SPA pageview hook (admin paths skipped)
- Modal route is NOT in the SEO surface (intercepting routes only fire on client-side nav)
- `/blogs/[slug]` pinned to `runtime = 'nodejs'` so ISR renders don't fall through to Edge

Generated from the codebase at commit `main`. Pairs with `ARCHITECTURE.md` (text reference) and `CLAUDE.md` (AI contributor contract).